Documentación completa 2 3 Roles y permisos

Backend City Care | Versión 1.0

Resultado. El apartado 2.3 está terminado. City Care dispone de tres roles iniciales, una matriz centralizada de permisos, autorización por acción y aislamiento de los administradores de dependencia. El contrato OpenAPI, el cliente Orval, MySQL y las pruebas quedaron sincronizados.

Estado	Cobertura	Evidencia
COMPLETO	6 de 6 puntos del apartado 2.3	10 pruebas funcionales nuevas
VALIDADO	Sin regresiones en 2.1 y 2.2	33 de 33 pruebas aprobadas
SINCRONIZADO	MySQL, OpenAPI y Orval	Rol dependency_admin y función listRoles

1 Alcance terminado

Punto	Implementación	Estado
Tabla y relación	Se conserva roles y la relación users.role_id	Listo
Roles iniciales	admin, dependency_admin y user	Listo
Administrador de dependencia	Alcance obligatorio por dependency_id	Listo
Matriz de permisos	Servicio central con siete permisos	Listo
Endpoint de roles	GET /api/v1/admin/roles	Listo
Autorización granular	Middleware parametrizado por permiso	Listo

2 Modelo de roles

Rol	Alcance	Uso
admin	Global	Administra usuarios de todas las dependencias y asigna cualquier rol
dependency_admin	Su dependencia	Administra cuentas locales con rol user
user	Cuenta propia	Accede a autenticación y perfil; no usa rutas administrativas

Los permisos se resuelven mediante el slug del rol. Las rutas no preguntan solamente si el usuario es admin; cada una declara la acción exacta que requiere.

3 Matriz de permisos

Permiso	admin	dependency_admin	user
roles.list	Sí	Sí, solo asignables	No
users.list	Sí, global	Sí, dependencia	No
users.read	Sí, global	Sí, dependencia	No
users.create	Sí, global	Sí, dependencia	No
users.update	Sí, global	Sí, dependencia	No
users.status	Sí, global	Sí, dependencia	No
users.reset_password	Sí, global	Sí, dependencia	No

4 Reglas del administrador de dependencia

- El listado se limita a cuentas con rol user y dependency_id igual al de la cuenta autenticada.
- Consultar, editar, activar, desactivar o restablecer una cuenta externa devuelve 403.
- Solo puede crear usuarios dentro de su propia dependencia.
- Solo puede asignar el rol user; no puede crear admin ni dependency_admin.
- No puede administrar cuentas admin o dependency_admin aunque compartan dependencia.
- No puede mover un usuario a otra dependencia.
- La baja lógica y el restablecimiento de contraseña conservan la revocación de sesiones del 2.2.

5 Flujo de autorización

Etapa	Comprobación	Resultado de error
1 Autenticación	Bearer token válido y cuenta activa	401
2 Permiso	El rol contiene la acción requerida	403 E_PERMISSION_REQUIRED
3 Alcance	La dependencia está dentro del ámbito del actor	403 E_DEPENDENCY_SCOPE
4 Asignación	El actor puede asignar el rol solicitado	403 E_ROLE_ASSIGNMENT_FORBIDDEN
5 Jerarquía	El rol del objetivo puede ser administrado	403 E_ROLE_SCOPE
6 Operación	Validación y transacción del recurso	200, 201 o error uniforme

6 Endpoint de roles

GET /api/v1/admin/roles requiere roles.list. El administrador general recibe todos los roles. El administrador de dependencia recibe solamente user, porque es el único rol que puede asignar. Cada registro incluye id, name, slug, description y permissions.

```
GET /api/v1/admin/roles
Authorization: Bearer <token>

{ "data": [{ "id": 3, "name": "Usuario", "slug": "user", "permissions": [] }] }
```

7 Integración con perfil y frontend

El transformador de usuario incluye role.permissions en las respuestas de login, perfil y operaciones administrativas. El frontend puede usar esa lista para ocultar acciones no permitidas. El backend sigue siendo la autoridad final y vuelve a comprobar cada permiso.

8 Base de datos y seeder

No se agregó una tabla ni una migración. La tabla roles ya soportaba el tercer rol. El seeder fue actualizado y ejecutado sobre MySQL para registrar dependency_admin de forma idempotente. Las seis migraciones permanecen en estado completed.

Slug	Nombre	Descripción
admin	Administrador	Acceso administrativo global
dependency_admin	Administrador de dependencia	Administra usuarios de su dependencia
user	Usuario	Acceso normal al sistema

9 Archivos principales

Archivo	Responsabilidad
authorization_service.ts	Matriz, comprobación de alcance y roles asignables
permission_middleware.ts	Exige un permiso específico antes del controlador
roles_controller.ts	Publica roles asignables y sus permisos
admin_users_controller.ts	Aplica el alcance por dependencia
new_account_controller.ts	Impide altas externas o escalamiento de rol
admin_seeder.ts	Registra los tres roles iniciales
roles_permissions.spec.ts	Pruebas del apartado 2.3

10 OpenAPI y Orval

El contrato publica RolesListApiResponse, permissions dentro de RolePublic y la operación listRoles. Orval regeneró sdk/generated/city-care.ts y expone la función listRoles.

```
npm run openapi:generate
listRoles(options)
```

11 Pruebas y cierre

Grupo	Casos
Roles	Matriz completa para admin y roles asignables para dependency_admin
Permisos	Usuario normal rechazado con 403
Aislamiento	Listado y detalle limitados por dependencia
Altas	Alta local permitida y alta externa rechazada
Escalamiento	Asignación de admin rechazada
Jerarquía	Estado y contraseña de roles superiores rechazados
Perfil	Permisos del rol visibles para el frontend

La suite finaliza con 33 de 33 pruebas aprobadas. TypeScript, ESLint, build, rutas, OpenAPI y Orval terminan sin errores. El apartado 2.3 queda cerrado; el siguiente bloque es 2.4 Dependencias.